

ESC Siantan — Rencana Keamanan, Biaya & Roadmap Teknis

Dokumen riset internal — ringkasan audit, keputusan, dan rencana pengembangan. Disusun 2026-07-03.

1. Ringkasan Eksekutif

Aplikasi ESC Siantan (React + Vite + Supabase + Vercel) telah melalui audit keamanan menyeluruh dan serangkaian perbaikan. Dokumen ini merangkum: (a) apa yang sudah diperbaiki, (b) apa yang masih perlu dikerjakan, (c) estimasi biaya pada berbagai skenario pertumbuhan jemaat, dan (d) roadmap teknis 10 tahun ke depan.

Status jemaat saat ini: ~200 orang. Biaya operasional saat ini: ~Rp 35.000/tahun (hanya domain `escsiantan.my.id`) — seluruh layanan lain (Vercel, Supabase, Fonnte, Web Push) masih dalam kuota gratis.

2. Audit Keamanan — Temuan & Status Perbaikan

2.1 Sudah Diperbaiki (selesai, sudah di-deploy)

Masalah	Risiko	Perbaikan
Tidak ada rate limiting	Brute-force login, spam OTP, enumerasi nomor HP	Rate limiter IP-based ditambahkan ke `login-phone`, `check-phone`, `activate-request`, `wa-reset-request`
OTP pakai `Math.random()`	Kode OTP secara teori bisa ditebak	Diganti ke `crypto.randomInt()` (CSPRNG)
Password minimal 6 karakter	Password lemah seperti "123456" diterima	Dinaikkan ke minimal 8 karakter + wajib huruf & angka
Stack trace bocor ke client	Info struktur kode internal terekspos ke penyerang	Dihapus dari response error `delete-user.js`
CORS tidak dikonfigurasi	API bisa dipanggil dari domain manapun	Ditambahkan header CORS + security headers (X-Frame-Options, X-Content-Type-Options, dll) di `vercel.json`

Ikon notifikasi jadi kotak putih di Android	Bug kosmetik, bukan keamanan	Badge icon dipisah jadi versi monochrome (`badge-96.png`) dari icon berwarna
---	------------------------------	--

2.2 Perubahan Arsitektur OTP — Email-First

Sebelum: seluruh OTP (aktivasi akun & reset password) selalu lewat WhatsApp (Fonnte).

Sesudah: email (Supabase Auth OTP, gratis) jadi jalur utama; Fonnte WhatsApp otomatis jadi fallback bila user tidak punya email nyata atau pengiriman email gagal.

Alasan: mengurangi ketergantungan pada satu vendor pihak ketiga (Fonnte, unofficial WhatsApp API yang bisa diblokir Meta kapan saja), sekaligus tetap mempertahankan jalur WA untuk jemaat lama yang belum punya email terdaftar.

Status implementasi kode: selesai (`api/activate-request.js`, `api/activate-verify.js`, `api/wa-reset-request.js`, `api/wa-reset-verify.js`).

Yang masih perlu dikerjakan (aksi user):

- Setup SMTP kustom di Supabase Dashboard (Authentication → Settings → SMTP). Default Supabase Free hanya 3 email/jam — tidak cukup bila beberapa jemaat request OTP bersamaan.
- **Kendala ditemukan:** percobaan setup Brevo SMTP gagal karena masalah verifikasi DNS record (SPF) di panel domain — error "An issue was encountered while updating the DNS records" dari sisi registrar, bukan dari Brevo/Supabase.
- **Opsi berjalan saat ini:** Resend.com (100 email/hari gratis, khusus transactional email) direkomendasikan sebagai pengganti. Bisa mulai dengan sender `onboarding@resend.dev` tanpa verifikasi domain dulu, verifikasi domain custom menyusul kapan saja tanpa perlu ubah kode.

2.3 Belum Dikerjakan (rekomendasi lanjutan)

Item	Prioritas	Catatan
Halaman Backup Data Admin (export Excel/ZIP)	Tinggi	Belum ada backup di luar Supabase — risiko kehilangan data permanen bila akun bermasalah
Audit log perubahan data sensitif	Sedang	Admin bisa hapus/ubah data tanpa jejak tercatat
2FA/TOTP untuk Admin & Super Admin	Sedang	Lapisan keamanan tambahan untuk akun berhak akses tinggi
Session management (lihat/revoke device aktif)	Rendah	Berguna saat jemaat >1000
Automated penetration testing berkala	Rendah	Relevan saat aplikasi jadi lebih kritikal (transaksi keuangan, dsb)

3. Analisis Biaya

3.1 Kondisi Saat Ini (~200 Jemaat)

Layanan	Biaya	Catatan
Vercel Hosting (Free)	Rp 0	100 GB bandwidth/bulan — jauh cukup
Supabase (Free)	Rp 0	500 MB database, 1 GB storage — cukup untuk 200 jemaat (~100-150 MB terpakai)
Fonnte WhatsApp (Free)	Rp 0	Kuota 999 pesan gratis, sekarang hanya dipakai sebagai fallback
Web Push (VAPID)	Rp 0	Standar terbuka W3C, tidak ada biaya
Domain `escsiantan.my.id`	Rp 35.000/tahun	Satu-satunya biaya rutin saat ini
Total	~Rp 35.000/tahun (~Rp 3.000/bulan)	

3.2 Proyeksi Skenario 1.000 Jemaat

Layanan	Opsi Hemat	Opsi Aman Penuh
Vercel	Free (~Rp 0)	Pro \$20/bln (~Rp 320rb) — DDoS protection lanjutan
Supabase	Free (~Rp 0), storage perlu dipantau	Pro \$25/bln (~Rp 400rb) — backup harian otomatis + PITR 7 hari, storage 8 GB
Fonnte	Free (fallback saja)	Free (fallback saja)
Domain	Rp 35rb/tahun	Rp 35rb/tahun
Total	~Rp 3rb/bulan	~Rp 723rb/bulan

Rekomendasi: pada 1000 jemaat, backup data otomatis (Supabase Pro) jadi prioritas utama — bukan opsional. Kehilangan data 1000 jemaat jauh lebih mahal daripada Rp 400rb/bulan.

4. Perubahan Formulir Pendaftaran (Baptisan, Nikah, Penyerahan Anak)

Ditemukan kesenjangan antara formulir digital dengan formulir kertas resmi gereja (dibandingkan dari dokumen referensi `PERNIKAHAN.txt`, `BAPTISAN.txt`, `PENYERAHAN ANAK.txt`). Field yang hilang sudah dilengkapi:

- **Pernikahan:** +18 kolom baru (migrasi v29) — tempat lahir, no. KTP, nama akun Disdukcapil, alamat, status pernikahan sebelumnya, no. HP orang tua, tanggal & gereja baptisan — masing-masing untuk mempelai pria & wanita. Dokumen direstrukturisasi jadi 8 item terpisah pria/wanita.
- **Baptisan:** + dokumen Kartu Keluarga (sebelumnya tidak ada)
- **Penyerahan Anak:** + dokumen KTP Ayah & KTP Ibu (sebelumnya digabung)
- Ketiga formulir kini menampilkan info "yang harus dikumpulkan langsung ke Resepsionis" (pas foto, materai, surat pernyataan) sesuai formulir resmi.

Status: kode sudah selesai & di-deploy. **Aksi tertunda:** migrasi SQL v29 harus dijalankan manual di Supabase SQL Editor sebelum formulir Pernikahan berfungsi penuh.

5. Roadmap Teknis 10 Tahun

Fase 1 — Q3 2026 (selesai)

Rate limiting, CORS, CSP, password policy, hapus stack trace, email-first OTP, kelengkapan formulir pendaftaran sakral.

Fase 2 — Q4 2026

- Halaman Backup Data Admin (export Excel/ZIP manual bulanan)
- Audit log perubahan data sensitif
- Setup SMTP produksi (Resend/Gmail) — pastikan email OTP andal

Fase 3 — 2027–2028

- Evaluasi upgrade Supabase Pro bila jemaat mendekati 500-1000 (backup otomatis, PITR)
- 2FA/TOTP untuk Admin & Super Admin
- Content Security Policy (CSP) headers lebih ketat

Fase 4 — 2029–2031

- Evaluasi self-hosted Supabase bila jemaat >5000
- End-to-end encryption untuk data sensitif (NIK, dokumen)
- Automated penetration testing berkala
- React/Vite major version upgrade

Fase 5 — 2032–2036

- Zero-trust architecture
 - Passkeys/WebAuthn (login tanpa password)
 - Multi-region deployment (redundansi data)
 - AI-based threat detection
-

6. Daftar Aksi Tertunda (Ringkasan)

1. **Jalankan migrasi SQL v29** di Supabase SQL Editor (formulir Pernikahan)
2. **Selesaikan setup SMTP** (Resend/Gmail) untuk email OTP produksi
3. **Bangun halaman Backup Data Admin** — prioritas tertinggi untuk perlindungan data
4. Pertimbangkan audit log untuk perubahan data sensitif oleh admin
5. Pantau penggunaan storage Supabase seiring pertumbuhan jemaat

Dokumen ini adalah snapshot kondisi & rencana per 2026-07-03. Perbarui saat ada perubahan signifikan pada arsitektur, biaya, atau jumlah jemaat.